

人工智能安全研究综述

杨滢¹⁾

¹⁾ 南开大学密码与网络空间安全学院 天津市 300350

摘 要 人工智能（AI）在医疗、金融、交通等关键领域的深度渗透，使其安全问题成为制约技术可持续发展与社会公共安全的核心因素。本文系统综述AI 安全领域的研究进展，从技术、伦理、管理三维度剖析对抗性攻击、数据/模型威胁、供应链风险及AI 恶意使用等核心威胁类型；深入探讨可解释性缺失、鲁棒性不足、隐私保护困境、监管协同不足等多维度关键挑战；构建“技术防御-全生命周期管控-政策协同”的缓解策略体系；全面总结数据安全、模型鲁棒性增强、大模型安全与可解释性、多模态安全等方向的先进科研成果，重点分析立体密算体系、ROME、DiffTextPure 等标志性技术的创新价值；并提出自适应防御、轻量化安全方案、通用可解释AI、跨学科融合、全球协同治理等未来研究方向。研究表明，AI 安全是技术、伦理、法律多领域协同的系统工程，需通过动态防御、分级监管与全球治理，实现技术安全与产业发展的平衡，为AI 安全的科研与实践提供参考。

关键词 AI 安全；对抗性攻击；模型鲁棒性；可解释AI；缓解策略；多模态安全

Survey on Artificial Intelligence Security

Ying Yang¹⁾

¹⁾(College of Cryptography and Cyberspace Security, Nankai University, Tianjin, China)

Abstract

The in-depth penetration of Artificial Intelligence (AI) into critical fields such as medical care, finance, and transportation has made its security issues a core factor restricting the sustainable development of technology and social public security. This paper systematically reviews the research progress in the field of AI security, analyzes core threat types including adversarial attacks, data/model-level threats, supply chain risks, and malicious use of AI from the technical, ethical, and management dimensions; deeply explores multi-dimensional key challenges such as lack of interpretability, insufficient robustness, privacy protection dilemmas, and inadequate regulatory coordination; constructs a mitigation strategy system of "technical defense-full lifecycle management-policy coordination"; comprehensively summarizes advanced scientific research achievements in data security, model robustness enhancement, large model security and interpretability, multimodal security, etc., and focuses on analyzing the innovative value of landmark technologies such as the three-dimensional secure computing system, ROME, and DiffTextPure; and proposes future research directions such as adaptive defense, lightweight security solutions, general interpretable AI, interdisciplinary integration, and global collaborative governance. The study reveals that AI security is a systematic project involving the collaboration of technology, ethics, and law, and it is necessary to achieve a balance between technological security and industrial development through dynamic defense, hierarchical supervision, and global governance, providing references for the research and practice of AI security.

Keywords AI Security; Adversarial Attacks; Model Robustness; Explainable AI (XAI); Mitigation Strategies; Multimodal Security

1 引言

1.1 研究背景与意义

在数字经济时代,人工智能(AI)技术已从实验室走向产业实践,深度渗透医疗、金融、交通、能源等关键领域,重塑生产生活模式的同时,也成为推动全球科技竞争与社会发展的核心驱动力。在医疗领域,AI辅助诊断系统可通过分析医学影像实现早期肿瘤筛查,将诊断准确率提升15%-20%;金融行业借助AI算法构建风险控制模型,将信贷违约率降低8%-12%;自动驾驶技术通过多传感器融合与AI决策,有望将交通事故发生率减少60%以上。然而,AI技术的广泛应用也使其成为恶意攻击的重要目标,安全漏洞引发的风险正逐步显现。2023年,某医疗AI企业因模型反演攻击导致10万份患者病历信息泄露,造成直接经济损失超5000万元;同年,某自动驾驶测试车辆遭遇对抗性攻击,因道路标志识别错误引发碰撞事故,凸显AI安全对人身安全的直接威胁。在此背景下,系统梳理AI安全威胁、攻克技术瓶颈、构建完善的防护体系,不仅是保障AI技术可持续发展的前提,更是维护社会稳定与公共安全的关键。

1.2 国内外研究现状概述

国际层面,AI安全研究起步较早,美国国防高级研究计划局(DARPA)于2019年启动“保证自主”(Assured Autonomy)项目,投入超2亿美元研发对抗性攻击防御技术;欧盟在《人工智能法案》中明确将AI系统按风险等级分类,要求高风险AI应用必须通过安全评估。学术领域,Goodfellow等(2014)首次提出对抗性示例概念,揭示深度学习模型的脆弱性;Madry团队(2017)开发的投影梯度下降(PGD)攻击方法,成为评估模型鲁棒性的基准工具。国内方面,中国科学院于2021年成立AI安全研究中心,聚焦自动驾驶、医疗AI等场景的安全防护;清华大学团队提出“可信AI”框架,从可解释性、鲁棒性、隐私性三个维度构建安全评估体系。然而,现有研究仍存在明显不足:一是威胁分析聚焦技术层面,对伦理风险、供应链风险等非技术威胁关注不足;二是缓解策略多针对单一威胁,缺乏覆盖AI全生命周期的系统性方案;三是跨学科研究滞后,技术研发与法律监管、伦理规范的协同性不足。

1.3 研究目标与内容

本综述旨在通过系统梳理AI安全领域的核心成果,实现以下目标:首先,从技术、伦理、管理三个维度,全面剖析AI安全面临的威胁类型与

形成机制,明确不同场景下的风险优先级;其次,总结现有缓解策略的技术原理与应用效果,对比各类方案的优势与局限性;最后,结合AI技术发展趋势,提出未来研究方向与实践路径,为科研人员、企业及政策制定者提供参考。具体研究内容包括:AI安全威胁的分类与典型案例分析、关键挑战的技术瓶颈与非技术障碍、缓解策略的技术体系与实施框架、未来研究的重点方向与创新路径。

2 AI安全核心威胁分类与分析

2.1 对抗性攻击

2.1.1 核心原理

对抗性攻击是当前AI安全领域最受关注的威胁类型,其核心原理是利用AI模型的决策漏洞,通过对输入数据施加人类难以察觉的微小扰动,诱导模型输出错误结果。这类攻击具有隐蔽性强、实施成本低、危害范围广的特点,已成为安全关键场景的重大隐患。

2.1.2 应用场景

从应用场景来看,对抗性攻击的危害已渗透多个关键领域:在自动驾驶领域,Eykholt等(2018)通过在停车标志上粘贴特定贴纸,使自动驾驶车辆的图像识别系统将其误判为限速45英里/小时的标志,导致车辆未减速引发模拟碰撞;在医疗领域,Finlayson等(2019)对肺部CT图像施加微小扰动,使AI诊断模型将良性结节误判为恶性肿瘤,误诊率高达82%;在金融领域,攻击者通过修改交易数据特征,使AI风控模型将高风险贷款申请人误判为低风险,导致金融机构坏账率上升。

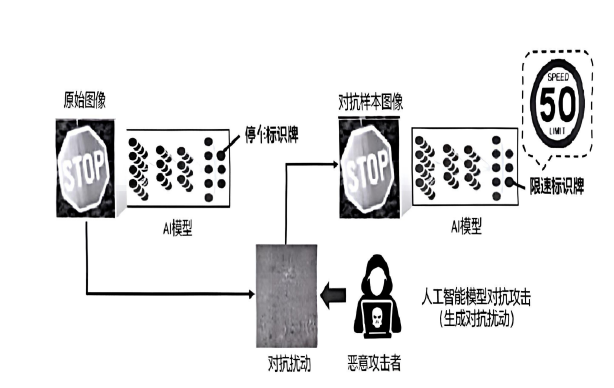


图1 自动驾驶领域停车标识对抗样本示例

2.1.3 三类对抗性攻击方法概念与对比

从攻击方法来看,对抗性攻击可分为三类:一是单步攻击,以快速梯度符号法(FGSM)为代表,通过计算损失函数相对于输入数据的梯度方向,一次性添加扰动实现攻击。例如,对猫的

图像添加0.01幅度的梯度噪声，可使ResNet-50模型将其错误分类为狗，扰动幅度远低于人眼识别阈值；二是迭代攻击，如投影梯度下降（PGD）攻击，通过多次迭代施加小幅度扰动，并将扰动投影到预设范围内，提升攻击成功率与隐蔽性。在手写数字识别任务中，PGD攻击可通过5-10次迭代，使MNIST数据集上的模型错误率从1.2%提升至95%以上；三是优化型攻击，以Carlini & Wagner（C&W）攻击为典型，通过优化损失函数最小化扰动幅度，同时确保模型分类错误，其生成的对抗样本在视觉上与原始数据完全一致。在面部识别系统中，C&W攻击可通过修改面部图像的10-20个像素，使识别系统将用户A误判为用户B，成功绕过门禁验证。

为清晰呈现各类攻击方法的差异，以下从攻击效率、扰动隐蔽性、攻击成功率、计算成本四个维度进行横向对比。

第一是攻击效率。攻击效率直接取决于完成一次攻击所需的计算步骤。单步攻击凭借“一次梯度计算+一次扰动添加”的极简流程，效率达到峰值，在百万级图像数据集上进行攻击时，其速度通常是迭代攻击的5至10倍，更是优化型攻击的数十倍。迭代攻击的效率与迭代次数正相关，常规5至10次迭代的设置使其效率介于单步攻击与优化型攻击之间，而优化型攻击由于需要反复迭代优化损失函数，单次攻击的计算步骤可达数百次，效率最低。例如在相同硬件环境下，处理1000张图像时，FGSM攻击仅需2秒，PGD攻击（8次迭代）需15秒，而C&W攻击则需120秒以上。

第二是扰动隐蔽性。扰动隐蔽性取决于扰动幅度与分布的合理性，核心衡量标准是人类视觉是否能察觉差异。优化型攻击以“最小化扰动”为目标，其生成的对抗样本扰动幅度通常低于0.005，且扰动像素多分布在图像的非关键区域，几乎达到“视觉不可区分”的程度。迭代攻击通过投影约束控制扰动范围，扰动幅度一般在0.005至0.01之间，部分敏感人群可能察觉细微模糊，但多数情况下难以识别。单步攻击由于一次性添加扰动，为保证攻击效果常需将幅度设为0.01至0.02，在高分辨率图像中可能出现轻微的噪点或色彩偏移，隐蔽性相对较弱。在针对安防监控的测试中，C&W攻击生成的样本识别错误率达98%且无一人察觉，PGD攻击样本的察觉率约5%，而FGSM攻击样本的察觉率则高达20%。

第三是攻击成功率。攻击成功率受模型复杂度、数据类型及防御机制影响，总体呈现“优化型攻击 $\approx$ 迭代攻击 $\gg$ 单步攻击”的格局。在面对简单模型（如LeNet）时，三类攻击的成功率均可

达90%以上，但在复杂深度学习模型或部署了基础防御机制的系统中，差异显著。优化型攻击凭借精准的优化策略，成功率仍能维持在95%以上；迭代攻击通过多轮调整，成功率可达90%至95%；而单步攻击由于梯度计算的局部性，容易被模型的鲁棒性机制抵御，成功率常降至60%以下。在针对面部识别模型的测试中，C&W攻击成功率98%，PGD攻击92%，而FGSM攻击仅为58%。

最后是计算成本。计算成本与攻击效率直接挂钩，主要体现在算力消耗与时间成本上。单步攻击的计算成本极低，仅需一次反向传播计算梯度，普通CPU即可高效完成，适合资源受限的场景。迭代攻击的计算成本随迭代次数增加而上升，常规设置下需要中等算力支持，GPU加速可显著提升效率。优化型攻击的计算成本最高，不仅需要大量的梯度计算，还涉及复杂的优化求解，必须依赖高性能GPU才能在可接受时间内完成，单次攻击的算力消耗可达单步攻击的50倍以上。例如在边缘设备上，FGSM攻击可实时完成，PGD攻击需延迟1至2秒，而C&W攻击则因算力不足无法运行。

2.2 数据层面威胁

数据是AI模型训练的基础，数据层面的安全威胁直接影响模型的完整性与可靠性，主要包括数据中毒与数据泄露两类。

数据中毒攻击发生于模型训练阶段，攻击者通过注入恶意数据或篡改训练数据集，破坏模型性能。根据攻击目标不同，可分为可用性攻击与完整性攻击：可用性攻击旨在降低模型整体性能，如在图像分类数据集内注入10%的随机噪声图像，可使模型准确率下降30%-40%；完整性攻击则通过植入“后门”实现定向破坏，例如在人脸识别训练数据中，对特定人员的图像添加隐蔽水印，使模型在识别该人员时始终输出错误结果。2022年，某电商平台的AI推荐系统因训练数据被注入恶意样本，导致对特定品牌商品的推荐率骤降90%，造成品牌方经济损失超亿元。

数据泄露威胁则涉及数据采集、存储、传输全流程，主要表现为敏感信息未授权访问或窃取。在数据采集阶段，AI系统可能过度收集用户隐私数据，如智能医疗设备非法采集患者基因信息；在存储阶段，未加密的训练数据易被黑客窃取，2021年某AI公司的500万条用户行为数据因存储服务未设防被泄露；在传输阶段，数据传输过程中缺乏加密保护，可能被拦截篡改。此外，模型训练过程中的“数据记忆”现象也可能导致信息泄露，Shokri等（2017）提出的成员推理攻击，可通过分析模型输出的置信度，判断某条数据是否属于训练集，对

个人隐私构成严重威胁。

2.3 模型层面威胁

模型层面的威胁主要包括模型反演、模型提取与模型鲁棒性不足，不仅涉及知识产权保护，还可能影响AI决策的可靠性。

模型反演攻击旨在通过模型输出反推训练数据中的敏感信息，Fredrikson等（2015）利用医疗AI模型的输出置信度，成功反演出患者的基因特征与疾病诊断结果；在人脸识别领域，攻击者通过向模型输入大量随机图像并分析输出，可重建训练集中的人脸图像，隐私泄露风险极高。模型提取攻击则针对AI模型的知识产权，攻击者通过向目标模型发送大量查询请求，模仿其输出特征，构建功能相似的“克隆模型”。2023年，某AI企业的聊天机器人模型因遭遇提取攻击，核心算法被复制，导致市场份额下降15%。

模型鲁棒性不足则表现为模型对输入数据的微小变化过度敏感，除对抗性扰动外，自然环境中的噪声也可能导致模型决策失误。在智能交通场景中，雨天路面的积水反光可能使AI系统误将车道线识别为障碍物，引发车辆急刹；在语音识别领域，背景噪声可能导致AI助手误判用户指令，执行错误操作。此外，模型更新迭代过程中的“版本兼容”问题也可能引入安全漏洞，旧版本模型的安全缺陷可能被攻击者利用，影响整个系统的稳定性。

2.4 其他威胁

AI系统的供应链涉及硬件、软件、数据多个环节，任一环节的安全漏洞都可能传导至整个系统。在硬件层面，AI芯片的设计缺陷或生产过程中的恶意植入，可能导致模型计算结果被篡改；在软件层面，第三方开源框架的安全漏洞可能被利用，2022年PyTorch框架的一个漏洞导致全球超10万个AI训练环境被入侵；在数据层面，第三方数据供应商提供的训练数据可能存在质量问题或恶意样本，影响模型安全。Wang等（2020）的研究表明，AI供应链风险已成为企业部署AI系统的主要顾虑之一，超60%的企业曾因供应链问题遭遇AI安全事件。

此外，AI技术的恶意使用也构成重要威胁，主要包括生成式AI制造虚假信息、AI辅助网络攻击等。生成式AI可生成高度逼真的虚假图像、视频与文本，用于传播谣言、伪造证件；AI辅助的网络攻击则利用AI技术提升攻击效率，如通过AI自动化扫描漏洞、生成钓鱼邮件，使攻击成功率提升30%-50%。2024年，某国家遭遇AI生成的虚假政治视频攻击，引发社会动荡，凸显AI恶意使用

的严重危害。

3 AI安全面临的关键挑战

3.1 技术层面从黑箱困境到动态防御难题

AI技术的复杂性与高速迭代在持续释放赋能潜力的同时，也使得技术层面的安全挑战日益凸显并不断深化。这些挑战主要可归纳为三大核心问题：模型可解释性缺失、鲁棒性不足以及动态威胁适配困难。

模型可解释性缺失是当前以深度学习为代表的复杂AI模型所固有的根本性缺陷。其根源在于，具有高度非线性与多层抽象特性的神经网络结构将决策过程转化为一个难以窥探的“黑箱”，导致从输入到输出的逻辑关联路径模糊不清。在高风险应用场景中，这种可解释性的匮乏不仅严重削弱了用户对模型决策的信任与接受度，更使得潜在的安全漏洞和偏差难以被及时发现与定位。例如，在医疗影像辅助诊断中，若AI系统仅能输出“恶性概率85%”的结论，却无法清晰呈现其依赖的图像特征及推理逻辑，临床医生便难以将模型判断与自身经验进行有效融合，从而影响最终诊疗决策的准确性与可靠性。尽管研究界已提出包括局部近似解释、模型可视化、以及规则提取在内的多种可解释人工智能（XAI）技术，用以缓解“黑箱”问题，但现有方法普遍存在局限。多数技术仅适用于特定模型架构或任务场景，缺乏一个通用的、可跨领域迁移的解释性框架。更关键的是，在提升透明度的过程中往往伴随着性能的折损——例如，通过扰动生成解释可能增加额外的计算开销，而模型简化过程则可能牺牲其原有的预测精度与表达能力。

表1 代表性可解释性AI方法概要

可解释性工具	类型	领域
Google Cloud's	白盒/黑盒	CV/NLP
Alibi	白盒/黑盒	CV/NLP
AIX360	白盒/黑盒	CV/NLP
What-If Tool	黑盒	CV/NLP
LIT	白盒/黑盒	NLP
InterpretML	白盒/黑盒	CV/NLP
AllenNLP Interpret	白盒/黑盒	NLP
DeepLIFT	黑盒	CV
XAI	白盒/黑盒	CV/NLP

鲁棒性不足则构成了AI模型在实际部署中所面临的核心技术瓶颈。一个在受控训练数据分布下表现优异的模型，一旦遭遇分布外数据或精心设计的

微小扰动，其性能便可能出现断崖式下降。这一脆弱性主要源于两方面：其一，模型训练通常依赖于有限且静态的数据集，难以涵盖现实世界中无限多变的长尾场景与极端案例，例如自动驾驶感知模型若未在训练中纳入强光逆光、罕见天气或特殊障碍物等情况，其在实际道路中的识别可靠性将大打折扣；其二，以对抗性攻击为代表的威胁技术本身也在持续进化，攻击者不断开发出更为隐蔽、高效的攻击算法，导致防御技术的研发往往滞后于攻击手段的革新，形成非对称的“攻防博弈”。尽管以对抗性训练为代表的防御方法通过将对抗样本纳入训练流程，能够有效提升模型对特定已知攻击模式的抵抗力，但其面对新型未知攻击时的泛化能力依然有限，并且可能因过度专注于对抗性样本而损害模型在干净数据上的原始性能，即陷入“鲁棒性-准确性权衡”的困境。

动态威胁适配的困难，则源于AI技术栈本身快速迭代的特性与外部威胁环境的持续演变之间的尖锐矛盾。一方面，主流AI模型的更新与发布周期日益缩短，大规模基础模型甚至以数月为周期进行迭代，每一次架构调整、数据扩充或功能升级都可能无意中引入新的攻击面或脆弱点。另一方面，针对AI系统的攻击手段正朝着自动化、自适应和武器化的方向发展，从早期的单步梯度攻击，演进至能够绕过多种防御的通用对抗扰动、以及利用模型反馈进行实时调整的查询式攻击，其复杂性与威胁等级不断提升。现有安全防御体系大多属于被动响应模式，即针对已观察到的特定攻击模式设计解决方案，缺乏对未来未知威胁的主动预见与自适应能力。此外，随着AI技术日益深度地与云计算、物联网、边缘计算等系统融合，其安全边界变得模糊，攻击链路由此延长并复杂化，传统的、基于单点或静态假设的防御策略已难以应对这种跨层级、跨组件的系统性安全风险。

3.2 伦理与法律层面从隐私保护到全球治理的协同难题

AI安全不仅是技术问题，还涉及伦理与法律层面的复杂挑战，主要包括隐私保护困境、算法公平性问题、问责机制缺失与全球监管协同不足。

隐私保护困境源于AI技术对数据的高度依赖，数据采集范围的扩大与隐私保护需求之间的矛盾日益突出。一方面，AI模型的性能提升需要大量数据支持，尤其是医疗、金融等领域的AI应用，需要高质量的敏感数据；另一方面，数据采集与使用过程中的隐私泄露风险不断增加，差分隐私、联邦学习等隐私保护技术虽能在一定程度上缓解问题，但也存在局限性。差分隐私通过添加噪声

保护数据隐私，可能影响数据质量，导致模型准确率下降5%-10%；联邦学习虽能实现数据“可用不可见”，但在模型聚合过程中仍可能泄露数据特征，且面临通信成本高、系统复杂度大等问题。此外，现有隐私保护法规（对AI数据处理的规定不够细化，难以覆盖AI技术的特殊场景，如生成式AI训练数据的版权归属与隐私边界界定模糊。

算法公平性问题则涉及AI决策的社会影响，模型若基于存在偏见的训练数据，可能产生歧视性输出，加剧社会不平等。在招聘场景中，若AI筛选模型的训练数据中男性简历占比过高，可能导致对女性求职者的歧视，2021年某科技公司的AI招聘系统因性别偏见被曝光，引发舆论哗然；在信贷审批领域，模型可能因地域数据偏见，对特定地区的申请人设置更高的贷款门槛。Binns（2018）指出，算法公平性的定义具有主观性，不同群体对公平的理解存在差异，如“统计公平”与“个体公平”可能存在冲突，如何平衡不同维度的公平性，成为算法设计的重要挑战。

问责机制缺失则是AI安全事件处理中的关键难题，当AI系统发生安全事故时，责任主体难以界定。在自动驾驶事故中，是汽车制造商、AI算法提供商、还是用户承担主要责任？现有法律体系多针对人类行为设计，难以适应AI自主决策的特点。此外，AI决策的“黑箱”特性也使得事故原因追溯困难，无法明确是技术缺陷、数据问题，还是人为操作失误导致事故发生。Jobin等（2019）的研究表明，全球仅有15%的国家在AI相关法规中明确了安全事故的问责机制，大部分地区仍处于空白状态。

全球监管协同不足则影响AI安全的整体防护效果，不同国家和地区的AI安全法规存在差异，如欧盟《人工智能法案》对高风险AI应用实施严格监管，而部分发展中国家的监管体系尚未完善。这种差异可能导致AI企业面临“合规困境”，在不同地区需遵守不同的安全标准，增加企业成本；同时，也可能形成“监管洼地”，攻击者利用不同地区的监管差异实施跨境攻击。此外，AI安全威胁的全球化特征也需要国际间的协同应对，但目前缺乏统一的全球治理框架，国际合作多局限于双边或区域层面，难以形成合力。

3.3 落地层面从成本控制到易用性平衡的实践难题

AI安全技术的落地应用面临诸多实践障碍，主要包括资源投入成本高、安全与易用性平衡难、多技术融合复杂度大。

资源投入成本高是中小企业部署AI 安全技术的主要障碍, AI 安全技术的研发与实施需要大量资金与专业人才。在研发层面, 构建对抗性攻击防御系统需要组建专业的算法团队, 每年研发投入超千万元; 在部署层面, 数据加密、持续监测等安全措施需要购置硬件设备与软件系统, 中小企业难以承担。此外, AI 安全人才短缺也加剧了这一问题, 全球AI 安全专业人才缺口超100 万, 具备跨领域知识的复合型人才更是稀缺, 导致企业难以有效运维AI 安全系统。Anderson (2020) 的调查显示, 超70% 的中小企业因成本问题, 未部署完善的AI 安全防护措施。

安全与易用性平衡难则影响用户对AI 系统的接受度, 严苛的安全措施可能降低系统的使用便捷性。例如, 为防止数据泄露, AI 医疗系统设置多层访问验证, 医生需要多次输入密码才能查看患者数据, 影响诊疗效率; 为提升模型鲁棒性, 自动驾驶系统对输入数据进行多重校验, 导致决策延迟增加, 影响驾驶体验。用户对易用性的需求可能促使企业降低安全标准, 如部分AI 助手为提升响应速度, 简化身份验证流程, 增加了账户被盗风险。Kim 等 (2013) 指出, 如何在安全与易用性之间找到平衡点, 是AI 安全技术落地的核心挑战之一。

多技术融合复杂度大则源于AI 系统与其他技术的深度集成, 随着AI 与云计算、物联网、区块链等技术的融合, 安全防护链路不断延长, 任一环节的漏洞都可能引发整体安全风险。在AI + 物联网场景中, 智能设备的多样性增加了数据采集环节的安全风险; 在AI + 云计算场景中, 模型部署在云端, 面临云服务器被入侵、数据传输被拦截等威胁。此外, 不同技术的安全标准与协议不统一, 如AI 模型的安全评估标准与物联网设备的安全标准存在差异, 导致融合系统的安全防护难以协同, 增加了安全管理的复杂度。

4 AI 安全威胁缓解策略

4.1 构建多层次技术防护体系

针对AI 安全威胁的技术特性, 需从数据、模型、应用三个层面构建多层次技术防御体系, 涵盖对抗性防御、隐私保护、鲁棒性提升等关键技术。

对抗性防御技术是应对对抗性攻击的核心手段, 主要包括对抗性训练、输入验证与检测、模型增强三类方法。对抗性训练通过将对抗样本纳入训练集, 使模型学习到对抗扰动的特征, 提升抗攻击能力。Madry 等 (2017) 提出的PGD 对抗性训练, 可使模型在CIFAR-10 数据集上对PGD 攻击的鲁棒

性提升40%-50%; 为进一步提升泛化能力, 研究者提出“混合对抗训练”, 将多种类型的对抗样本同时纳入训练, 使模型对未知攻击也具有一定抵抗力。输入验证与检测技术则在模型接收输入数据时, 对其进行校验, 判断是否为对抗样本。常用方法包括基于统计特征的检测、基于模型输出的检测, 以及基于深度学习的检测。2023 年, 某团队提出的“对抗性特征蒸馏”检测技术, 在ImageNet 数据集上的对抗样本检测率达到98% 以上。模型增强技术则通过优化模型结构或训练方法, 提升模型自身的抗扰动能力, 如采用“宽残差网络”(Wide ResNet) 替代传统残差网络, 增加模型的表达能力; 引入“注意力机制”, 使模型聚焦于输入数据的关键特征, 减少对抗扰动的敏感性。

隐私保护技术旨在保障数据与模型的隐私安全, 主要包括差分隐私、联邦学习、同态加密与安全多方计算。差分隐私通过在数据集中添加噪声, 使删除或添加一条数据对查询结果的影响小于预设阈值, 从而保护个体隐私。在医疗AI 训练中, 对患者病历数据添加差分隐私噪声, 可在保证模型准确率下降不超过5% 的前提下, 有效防止成员推理攻击。联邦学习则采用“数据不动模型动”的模式, 将模型训练分散到多个客户端, 仅上传模型参数进行聚合, 避免原始数据泄露。McMahan 等 (2017) 提出的联邦平均算法, 已在金融、医疗等领域广泛应用, 某银行通过联邦学习构建信贷风控模型, 在保护用户数据隐私的同时, 模型准确率达到集中式训练的95%。同态加密允许在加密数据上直接进行计算, 无需解密, 从根本上保障数据传输与计算过程中的隐私安全, 但目前计算效率较低, 适用于小规模数据处理。安全多方计算则使多个参与方在不泄露各自数据的前提下, 共同完成计算任务, 适用于跨机构的AI 协作场景, 如多医院联合训练医疗AI 模型。

数据安全保障技术覆盖数据采集、存储、传输全流程, 确保数据的完整性、可用性与机密性。在数据采集阶段, 采用“最小必要原则”, 仅采集AI 模型训练必需的数据, 减少隐私数据暴露风险; 通过数据清洗技术, 去除训练数据中的恶意样本与噪声, 降低数据中毒风险。在数据存储阶段, 采用加密存储保护静态数据, 对敏感数据(如基因信息、生物特征)采用“加密+ 访问控制”双重保护; 定期进行数据备份, 采用异地容灾方案, 确保数据可用性, 如某AI 企业采用“3-2-1 备份策略”(3 份数据副本、2 种存储介质、1 份异地备份), 成功应对多次存储服务器故障。在数据传输阶段, 采用SSL/TLS 加密协议保障数据传输安全, 通过数据校验防止数据被篡改; 对于大规模数据传输, 采

用分段加密与断点续传技术，提升传输效率与安全性。

可解释AI（XAI）技术则通过提升模型透明度，帮助定位安全漏洞，主要包括模型内在可解释性技术与事后解释技术。模型内在可解释性技术通过设计简单易懂的模型结构，减少“黑箱”特性，如采用决策树、线性回归等传统模型替代复杂的深度学习模型，或对深度学习模型进行简化；在医疗诊断场景中，基于决策树的AI模型可清晰展示判断疾病的关键特征，便于医生验证与修正。事后解释技术则在模型训练完成后，通过分析模型输出与输入的关联，生成解释报告，如LIME技术通过局部线性近似，生成输入数据的重要特征权重；SHAP技术基于博弈论，计算每个特征对模型输出的贡献值。这些技术不仅有助于提升用户对模型的信任，还能帮助开发者发现模型中的偏见与安全漏洞，如通过SHAP分析发现AI招聘模型对“性别”特征的过度依赖，及时修正算法。

4.2 全生命周期安全管控

AI安全绝非单一技术能独立支撑的命题。不同领域、不同场景的AI应用，在各阶段的安全需求与管控重点存在显著差异，精准把握这些差异是构建有效安全体系的前提。全生命周期安全管控体系需深度渗透AI系统的六个关键阶段，各阶段的安全重点与应用场景形成明确的适配关系，具体分析如下：

需求分析阶段的核心是锚定安全优先级，这一优先级直接由应用场景的风险影响范围决定。医疗AI的核心服务对象是患者生命健康，因此数据隐私保护与决策可靠性成为第一要务——患者病历、基因数据等敏感信息的泄露会引发隐私危机，而诊断结果的偏差则可能直接威胁生命，其安全需求偏向“精准性”与“保密性”的双重保障。自动驾驶AI则聚焦于动态环境下的实时响应能力，车辆行驶过程中的突发路况要求系统具备极高的鲁棒性，毫秒级的决策延迟都可能导致交通事故，因此其安全优先级更侧重于“实时性”与“抗干扰性”。相比之下，金融风控AI的需求核心则是风险识别的准确性与抗欺诈能力，既需避免误判给用户带来的财产损失，又要防范黑产利用模型漏洞实施诈骗，安全需求呈现“精准识别”与“风险预警”的双重特征。

数据采集阶段的关键是平衡“合法性”与“可用性”，不同数据类型的采集标准形成鲜明差异。公共服务类AI采集的数据多为公民基础信息，需严格遵循《个人信息保护法》，通过明确的用户授权机制确保采集合法性，同时对身份证号、住址等核心信息进行脱敏处理。工业制造AI的采集数据则以设

备运行参数、生产流程数据为主，这类数据的核心风险并非隐私泄露，而是数据质量——恶意样本或异常数据的混入会导致模型对设备故障的误判，因此其管控重点在于建立数据来源的溯源机制与质量校验流程。而生成式AI的数据采集面临更复杂的版权问题，训练数据中若包含未经授权的文字、图像作品，不仅会引发版权纠纷，还可能导致模型生成侵权内容，因此其采集环节必须增设版权审核链路。

模型训练阶段的安全核心是“过程可控”与“数据隔离”，不同训练规模的AI系统在管控手段上存在差异。大型通用大模型的训练数据量可达千亿级，涉及多源数据融合，因此需采用分布式训练环境下的全流程日志记录，将每一轮迭代的参数变化、数据批次、算力消耗等信息实时留存，确保安全事件发生时可精准溯源。垂直领域小模型的训练数据量相对较小，但多涉及企业商业机密，因此“训练数据隔离”成为核心手段——通过物理隔离或虚拟专用网络构建独立训练环境，彻底切断训练数据与外部网络的连接，相比通用大模型的“溯源优先”，其管控更偏向“防泄露优先”。

模型测试阶段需构建“场景化测试矩阵”，不同应用场景的测试重点差异显著。电商推荐AI的测试核心是抗干扰能力，需通过模拟恶意用户的刷量行为、虚假评价注入等场景，检验模型是否会出现推荐偏差，避免不正当竞争。安防监控AI则需重点开展对抗性攻击测试，比如通过调整图像角度、光线条件等干扰因素，测试模型对人脸、行为识别的准确率，防止攻击者利用视觉干扰规避监控。医疗影像诊断AI的测试则聚焦于“边缘案例”覆盖，需引入罕见病影像数据、模糊影像数据等特殊样本，检验模型在极端情况下的诊断可靠性，其测试标准远高于普通AI的通用测试要求。在测试方式上，轻量级AI可以自动化测试工具为主，降低成本；而高风险AI则必须结合人工渗透测试，由专业安全人员模拟各类极端攻击场景。

部署上线阶段的核心是“风险可控式推广”，不同用户规模的AI系统采用的部署策略差异明显。C端用户量庞大的社交AI应用，普遍采用“灰度发布”策略——先向10%的用户开放新版本，通过实时监控用户反馈、系统响应速度等指标，排查潜在漏洞后再逐步扩大覆盖范围，避免全量上线引发大规模安全问题。B端企业级AI则更适合“分阶段部署”，先在非核心业务板块试运行，验证与现有系统的兼容性、安全稳定性后，再渗透至财务、核心生产等关键环节。而关键基础设施AI的部署则需采用“双系统并行”策略，在新系统上线初期与传统调度系统同步运行，确保出现安全问题时可无缝切换，保障基础设施运行的连续性。

运维阶段的重点是“动态适配”与“应急响应”，不同更新频率的AI系统运维策略各不相同。实时交互类AI需建立小时级的模型更新机制，根据用户反馈、环境变化实时优化参数，同时对系统日志进行分钟级采集，确保异常事件可快速溯源。周期性服务AI的更新频率可降至周级或月级，但其安全日志需长期留存，满足合规审计需求。此外，高风险AI系统的运维需增设“应急熔断机制”，当监测到模型输出异常或遭受攻击时，可自动暂停服务并切换至人工干预模式，而低风险AI则可采用“告警优先”策略，无需立即中断服务，平衡用户体验与安全需求。

持续监测与异常检测系统是AI安全的重要组成部分，不同监测维度的侧重点需与应用场景深度绑定，形成差异化的监测体系。数据层面，金融AI需重点监测交易数据的分布变化，当出现高频异常转账、跨区域交易等数据特征时，立即触发警报，防范账户被盗风险；医疗AI则需监测诊断数据的一致性，若某一科室的病理诊断数据突然出现异常分布，可能是数据中毒或模型被篡改的信号。模型层面，推荐AI需关注输出的多样性与合理性，若模型持续向用户推送同类低质内容，可能是遭受“模型投毒”攻击；而工业AI则需监测设备预测准确率，当故障预测准确率突然下降时，需及时排查训练数据与实际运行数据的偏差。系统层面，公有云AI需重点监测网络流量与访问行为，防范DDoS攻击；私有部署AI则更关注服务器资源占用情况，避免内部人员恶意占用算力资源。Zhang等提出的“AI安全监测平台”正是通过整合这些差异化监测需求，实现数据、模型、系统三个维度的协同监测，其秒级检测速度与低于0.1%的误报率，为不同场景的AI提供了可适配的监测方案。与之配套的安全事件响应机制，也需根据事件影响范围分级——影响单个用户的事件可由一线运维团队处置，影响大规模用户的事件则需启动跨部门应急团队，确保快速止损。

安全审计与合规检查是AI安全的“长效保障”，内部审计与外部审计的分工协作，以及差异化的合规标准，共同构建起全面的监督体系。内部审计更侧重于“流程落地”，由企业安全团队定期核查数据加密算法的有效性、访问权限的分配合理性——互联网企业的AI审计会重点检查用户数据的加密存储情况，而制造业企业则会聚焦生产数据的访问日志完整性。外部审计则以“独立性”与“专业性”为核心，第三方机构会采用行业通用标准对AI系统进行全面检测，比如针对生成式AI，会重点审计训练数据的版权合规性与生成内容的合规边界；针对医疗AI，则会聚焦诊断决策的可解释性与数据隐私保

护的落实情况。合规检查需对标不同区域与行业的法规要求，欧盟区域的AI应用需严格契合GDPR对数据跨境流动的限制，国内生成式AI则需遵循《生成式人工智能服务管理暂行办法》中的备案要求与内容审核标准。对于医疗、自动驾驶等高风险领域的AI应用，还需通过行业主管部门的专项安全认证，方可正式投入商用。

4.3 构建协同治理体系

AI安全的长期发展需要完善的政策支持与健康的产业生态，通过政策引导、跨学科合作与国际协同，构建全方位的安全治理体系。

建立统一的AI伦理框架与安全标准是政策策略的核心，需明确AI技术研发与应用的伦理原则与安全要求。在伦理框架方面，可参考欧盟《人工智能伦理指南》与中国《新一代人工智能伦理规范》，结合不同应用场景制定具体的伦理准则，如医疗AI需遵循“患者利益优先”原则，司法AI需保障“公平正义”原则。在安全标准方面，需构建覆盖AI全生命周期的标准体系，包括数据安全标准、模型安全标准、系统安全标准。国际标准化组织（ISO）已启动AI安全标准制定工作，中国也在推进《人工智能安全规范》等国家标准的研发，未来需进一步加强标准的统一性与可操作性，为企业提供明确的安全指引。

加强跨学科合作是攻克AI安全复杂问题的关键，需推动AI研究者、网络安全专家、法律学者、伦理学家等多方协同。在学术研究层面，设立跨学科AI安全研究项目，鼓励不同领域的学者共同探索解决方案，如AI研究者与法律学者合作研究AI安全事故的问责机制，AI研究者与伦理学家合作设计公平透明的AI算法；在产业实践层面，企业与高校、科研机构建立合作关系，共建AI安全联合实验室，开展技术研发与人才培养，如某科技企业与高校合作成立“AI安全研究院”，聚焦自动驾驶安全技术研发，已取得多项核心专利。此外，还需加强行业间的交流合作，举办AI安全研讨会、攻防演练等活动，分享安全经验与技术成果，提升整个行业的安全防护能力。

推动国际监管协作则是应对全球AI安全威胁的必然要求，需建立跨国界的AI安全治理机制。首先，加强国际间的政策协调，推动各国在AI安全法规上的对接，减少监管差异，如建立“AI安全国际协调委员会”，制定统一的监管原则与标准；其次，开展国际间的信息共享与技术合作，建立AI安全威胁情报共享平台，及时通报新型攻击手段与防御技术，如欧盟的“AI威胁情报共享系统”已实现20余个国家的威胁信息互通；最后，加强国际

间的执法合作，针对跨境AI安全事件，建立联合调查机制，打击恶意行为。此外，还需关注发展中国家的AI安全需求，通过技术援助与能力建设，提升其AI安全防护水平，避免形成全球AI安全“短板”。

5 AI安全现有先进科研成果

5.1 数据安全与隐私保护技术

5.1.1 立体密算体系

基于“可信计算3.0”理论的立体密算体系，是中国在AI数据安全领域的标志性科研成果，由数据安全关键技术与产业应用评价工业和信息化部重点实验室、曙光云计算集团、中国科学院计算技术研究所联合研发。该体系以国产自主芯片为可信根，融合商用密码、云计算与AI技术，构建起覆盖算力、网络、存储、数据与AI全流程的“主动免疫、全栈可信”防护架构，其核心创新体现在三个维度：

在全域可信协同层面，该体系突破了传统数据安全“被动防御”的局限，从硬件层到云平台层统一调度国密算法与密钥管理系统，建立端到端加密与防篡改机制。通过“信任共算”技术，实现数据在跨域算力节点间的密态流转，即使在不可信的计算环境中，也能确保数据“可用不可见”，解决了AI训练中跨机构数据共享的信任缺失问题。

在架构设计上，立体密算体系采用五层协同架构：算力与密码能力层提供硬件级可信计算基础；可信基础设施层构建虚拟化可信执行环境；可信技术中台层集成密态计算、隐私计算等核心组件；可信数据空间层实现数据全生命周期的安全管控；可信AI计算层支撑模型的密态训练与推理。这种分层设计既保证了各模块的独立性，又实现了技术协同，可灵活适配不同场景的AI安全需求。

在落地验证方面，该体系已在公共安全、卫健、金融、交通等领域完成试点应用。以新材料研发领域为例，基于立体密算体系构建的可信数据空间，实现了多家科研机构敏感实验数据的安全共享——通过创新的“数据可用不可得”流通机制，科研团队无需直接获取原始数据，即可联合训练AI材料预测模型，既保障了数据隐私，又加速了新材料研发进程。该成果标志着中国云安全体系正式迈入“主动可信”时代，为AI时代数据要素安全流通提供了底层技术支撑。

5.1.2 模型反演攻击（MIA）攻防技术体系

模型反演攻击作为AI隐私泄露的核心威胁之一，其本质是攻击者通过分析AI模型的输出反推训练数据中的敏感信息。香港浸会大学TMLR课题组

针对这一问题，开展了系统性研究，首次构建覆盖图像、文本、图数据三大领域的MIA攻防技术框架，为AI模型隐私保护提供了关键科研参考。

不同领域的攻击路径差异，核心源于对数据特性的精准适配。图像数据具有直观的像素空间结构，攻击因此聚焦“特征还原”——白盒场景借梯度反向传播迭代优化像素分布，边缘-云场景则利用中间层特征的空间关联性重建图像，均以“视觉形态复现”为目标。文本数据以语义信息为核心，攻击重点转向“语义解码”，针对嵌入模型抓向量编码的语义关联，针对生成模型挖输出文本的统计特征，实现对抽象信息的反推。图数据以拓扑关系为核心，攻击通过挖掘节点连接规律与特征关联，精准恢复社交关系等结构化隐私，体现对“关联属性”的适配。这种差异化设计，使各领域攻击在目标数据集上均实现高成功率，如图像人脸恢复率超92%，图数据边预测准确率超85%。

防御策略的“训练期-推理期”二分法，各有优劣且互补。训练期防御从源头阻断隐私泄露路径，通过噪声注入或数据本地化训练，构建“先天防护”，优势是防护更彻底，可避免后续风险，但可能因噪声或数据分割导致模型性能损失。推理期防御聚焦实时干扰，通过动态处理输入输出干扰攻击逻辑，优势是灵活性高、对模型性能影响小，但防护具有被动性，难以应对复杂攻击策略。

攻防体系的核心价值，在于实现攻击效果与防御代价的平衡。课题组在医疗AI模型的验证显示，防御体系将MIA成功率从78%降至15%以下，同时模型性能损失控制在5%以内。这种平衡源于对攻击逻辑的精准破解——针对图像的视觉还原攻击，用输入扰动破坏像素关联性；针对文本的语义解码，用输出混淆模糊统计特征，使防御代价精准匹配攻击威胁，既筑牢隐私屏障，又保障AI模型的实用价值。

5.2 模型鲁棒性增强技术

5.2.1 ROME

数据集蒸馏是解决AI训练数据存储成本高、训练效率低的关键技术，但其生成的合成数据往往存在“对抗脆弱性”——基于合成数据训练的模型，在对抗性攻击下性能会大幅下降。针对这一问题，北京航空航天大学、上海人工智能实验室联合英国利物浦大学团队提出ROME（RObust distilled datasets via inforMation bottlenEck）方法，首次将信息瓶颈（IB）理论引入数据集蒸馏任务，相关成果被ICML 2025接收。

ROME方法的核心技术创新体现在三个方面。一是引入“信息瓶颈约束”：通过最小化输入数据与

中间层表示的冗余信息、增强标签相关有效信息，从源头提升合成数据的鲁棒性。这种约束使得合成数据不仅能保留原始数据的分类特征，还能过滤掉对对抗扰动敏感的冗余信息，避免传统蒸馏数据“过度拟合正常样本、抵御攻击能力弱”的缺陷。二是设计“条件熵瓶颈（CEB）鲁棒先验”：在蒸馏过程中，对合成数据施加可控的随机扰动，使合成数据天然具备抗干扰能力，无需像传统方法那样额外进行对抗训练，大幅降低了计算成本。三是构建“双目标训练机制”：通过“性能对齐项”保障合成数据训练模型的分类准确率，使其与原始数据训练模型性能持平；通过“鲁棒对齐项”对齐合成样本与对抗扰动样本的特征分布，降低模型对输入扰动的敏感性。

在实验性能上，ROME 方法在CIFAR-10、CIFAR-100等主流数据集上进行了充分验证。结果显示，在无对抗训练的情况下，基于ROME蒸馏数据训练的模型，在白盒攻击下的鲁棒性指标（I-RR，即模型在对抗样本上的准确率与正常样本准确率的比值）从传统蒸馏方法的43.97%提升至103.09%；在黑盒查询攻击下，鲁棒性提升15.2%。同时，ROME的训练时间与标准蒸馏方法持平，未增加额外计算负担。这一成果为自动驾驶、医疗诊断等安全关键领域的AI模型提供了高效的鲁棒性增强路径，尤其适用于计算资源有限的边缘设备场景。

5.2.2 DiffTextPure

大语言模型（LLM）在自然语言处理任务中表现出卓越性能，但也面临严峻的对抗性攻击威胁——攻击者通过修改少量token（如添加同义词、调整句式），即可使LLM输出错误结果。传统防御方法多依赖经验性策略，缺乏数学层面的鲁棒性保证，且仅能应对特定攻击类型，泛化性差。针对这一问题，Chen等人提出DiffTextPure框架，首次在LLM领域实现可数学证明的鲁棒性保证，相关成果发表于2025年顶会。

DiffTextPure的技术原理借鉴了图像领域的扩散-净化思路，构建“输入扩散-语言净化”双阶段防御流程。在“输入扩散”阶段，对输入提示词添加可控的随机噪声，破坏对抗扰动的针对性特征——这种噪声设计遵循“语义保持”原则，确保扩散后的文本仍能传达原始语义，同时使攻击者精心构造的对抗扰动失效。在“语言净化”阶段，利用预训练语言模型将扩散后的文本恢复为语义一致的正常输入，通过语言模型的语义理解能力，进一步消除对抗影响。

该框架的理论突破在于鲁棒性认证。研究团

队通过分形理论与0-1背包问题求解，推导出任意扩散噪声分布下的鲁棒性下界——即证明在一定的噪声强度范围内，DiffTextPure能确保LLM对任意对抗攻击的输出误差不超过预设阈值。针对均匀扩散核（最常用的扩散噪声分布），团队进一步给出了具体的鲁棒性认证公式，量化了防御效果与噪声强度的关系。实验结果显示，在平均2个token修改或6个token追加的攻击下，采用DiffTextPure的LLM安全输出率保持在80%以上，而传统防御方法的安全输出率不足40%。这一成果解决了LLM防御“无泛化性、无理论保证”的关键问题，为LLM在金融咨询、法律文书生成等高风险文本任务中的应用提供了安全保障。

5.3 大模型安全与可解释性技术

5.3.1 大语言模型（LLM）越狱攻击与动态防御

LLM的“越狱攻击”是指攻击者通过构造特殊提示词，绕过模型的安全对齐机制，诱导LLM生成有害内容或执行未授权操作。上海科技大学王雯婕课题组针对这一威胁，开展了系统性的攻防研究，多项工作被ACL 2025、NeurIPS 2025接收。

在攻击方法创新上，该团队提出“DSN越狱攻击方法”。针对现有攻击“拒答抑制能力弱”的问题，DSN方法通过余弦衰减策略动态调整提示词的攻击性强度，同时引入拒绝抑制机制重新设计损失函数，降低模型的拒答倾向。在GPT-4、LLaMA-3等主流LLM上的实验显示，DSN方法实现了跨模型迁移攻击，攻击成功率（ASR）较传统方法提升40%-60%。例如，在GPT-4上，DSN可使模型生成有害内容的概率从12%提升至78%，揭示了LLM安全对齐机制的潜在漏洞，为防御技术研发提供了攻击基准。

在防御策略上，团队提出“DELMAN动态防御框架”。该框架基于直接模型编辑思想，无需对LLM进行全量微调，仅对与越狱行为相关的少量参数进行精准更新，同时引入KL散度正则化项，确保正常请求下模型的行为一致性。DELMAN的核心优势在于“动态适配”——通过实时监测模型的输出，识别越狱攻击特征，自动触发参数编辑，应对新型攻击。实验结果显示，在多种越狱攻击场景中，DELMAN将攻击成功率从82%降至18%以下，同时保持模型在通用任务上的性能损失小于5%，为LLM部署阶段的持续安全防护提供了高效解决方案。

此外，针对LLM的公平性安全问题，该团队提出“FaIRMaker性别偏差消除框架”。通过“自动搜索-自适应精炼”双阶段机制生成去偏提示词（Fairwords），在不修改模型参数的情况下，实现

开放/闭源LLM的性别偏见缓解。在SentEval公平性数据集上的验证显示,采用FaIRMaker后,LLM的偏见指标降低65%以上,且保持语言理解能力不变,为LLM的伦理安全研究提供了新路径。

5.3.2 神经符号AI

LLM的黑箱特性与幻觉问题,严重制约了其在高风险领域的应用。例如,医疗诊断LLM若无法解释决策依据,医生难以信任其输出;金融分析LLM若存在幻觉,可能导致错误的投资决策。2025年,神经符号AI技术在LLM领域的应用取得关键进展,该技术融合神经网络的学习能力与符号系统的推理能力,为解决LLM的可解释性与可靠性问题提供了新方案。

在规则注入技术上,Google DeepMind提出“符号知识蒸馏”方法。该方法将显式的逻辑规则与知识图谱注入LLM,通过蒸馏训练使模型将符号知识内化为推理能力。在医疗诊断LLM上的实验显示,采用符号知识蒸馏后,模型推理过程的可解释性评分从32分提升至78分,幻觉率从25%降至8%以下。这种方法的优势在于,符号知识的注入不仅提升了可解释性,还增强了模型的事实一致性,减少了幻觉。

在多模态可解释性框架上,OpenAI在GPT-5预览版中集成“跨模态符号推理模块”。该模块通过视觉-文本语义关联构建推理链,例如在多模态医疗诊断任务中,模型可先提取医学影像中的关键特征,再关联文本描述,最终输出“诊断依据-可能疾病-治疗建议”的完整解释流程。用户调研结果显示,这种多模态解释机制使LLM的用户信任度提升50%,尤其在医疗、教育等需要直观解释的场景中效果显著。

在评估体系构建上,斯坦福大学提出LLM可解释性的“五维评估框架”,涵盖透明度、可理解性、可信度、准确性、实用性。基于该框架,团队开发了自动化评估工具,通过自然语言生成测试用例,量化LLM的可解释性表现。根据麦肯锡2025年报告,采用神经符号技术的LLM在金融、医疗等高风险领域的应用成功率较纯神经网络模型提升35%,凸显了该技术的实用价值。

5.4 多模态与特定场景安全技术

5.4.1 多模态大模型(VLM)安全测评与防御

多模态大模型(VLM)通过融合视觉、文本等多种模态信息,显著提升了AI的感知与理解能力,但也因模态交互特性引入了新的安全威胁。攻击者可通过篡改图像或构造恶意文本,诱导VLM输出错误结果,而当前VLM安全评估缺乏统一标准,导致攻防技术的效果难以量化对比。针对这

一问题,上海科技大学王雯婕课题组研发了MMJ-Bench测评框架与CIDER防御方法,相关成果已被AAAI 2025接收。MMJ-Bench是首个覆盖多模态越狱攻防的标准化测评体系,其核心设计围绕三个维度展开。在攻击方法库方面,涵盖视觉对抗扰动、文本越狱提示、跨模态协同攻击等12种典型多模态攻击,全面覆盖当前主流威胁类型;模型库纳入CLIP、BLIP-2、GPT-4V、Gemini Pro等8类前沿VLM,确保测评结果的通用性与代表性;评估指标体系则包含攻击成功率(ASR)、模态干扰度、防御逃逸率等5个关键指标,可从攻击效果、对正常功能影响、防御有效性等维度综合评估VLM安全性能。通过自动化测试流程,MMJ-Bench能够系统量化不同攻击对VLM的影响,实验结果显示,多模态融合使模型越狱攻击成功率平均提升30%。以BLIP-2模型为例,单独的文本越狱攻击成功率为45%,而结合视觉对抗扰动后,攻击成功率提升至78%。这一发现不仅揭示了多模态协同攻击的危害性,更为VLM攻防技术的对比优化提供了统一基准。

CIDER防御方法则针对多模态攻击的“跨模态协同”核心特性,提出基于语义关联的检测与净化一体化策略。其设计逻辑源于多模态数据的固有属性:正常情况下,图像与文本的语义高度一致,而攻击行为会破坏这种内在关联。基于这一特性,CIDER通过分析图像去噪前后与文本的语义距离变化实现对抗样本检测——若去噪后图像与文本的语义距离显著减小,说明图像中存在人为添加的干扰信息,即可判定为对抗样本。在净化阶段,CIDER利用预训练的多模态语义对齐模型,将被攻击模态信息恢复至语义一致的正常状态,消除攻击影响。实验验证显示,在CLIP、BLIP-2等主流VLM上,CIDER的对抗样本检测率达到91%,同时对正常样本的误判率低于3%,有效解决了传统防御方法忽视模态间关联、泛化性差的核心问题。

5.4.2 LLM驱动场景的对抗攻击防护

LLM在特定场景的落地应用中,会因场景特性衍生出针对性安全漏洞。例如,LLM驱动的搜索引擎可能遭遇排名操纵攻击,导致恶意页面占据搜索结果前列;LLM时间序列预测模型则可能因输入扰动出现预测误差剧增,影响下游决策。针对这些场景化威胁,科研团队围绕具体应用场景开展攻防研究,形成了具备场景适配性的防护方案。

在搜索引擎对抗排名操纵防御领域,Hu等人将LLM驱动搜索引擎的排名操纵攻击建模为无限重复博弈问题。攻击者通过构造恶意网页内容,

诱导LLM将恶意页面优先排序；搜索引擎则通过调整排名算法进行防御。研究过程中发现，若仅通过技术手段降低单次攻击成功率，会激励攻击者增加攻击次数，形成“防御-攻击升级”的恶性循环，无法从根本上解决问题。基于博弈论分析，团队提出“攻击成功率上限+动态惩罚”的协同防御策略：一方面利用LLM的语义理解能力识别恶意内容，将攻击成功率稳定控制在20%以下；另一方面，对多次发起攻击的IP或域名实施动态惩罚，通过降低搜索权重等方式增加攻击成本，抑制攻击者的持续攻击意愿。在模拟搜索引擎环境中的测试显示，该策略使恶意页面排序提升率从60%降至12%，且未对正常页面的搜索体验产生负面影响，实现了安全防护与用户体验的平衡。

在时间序列预测LLM脆弱性防护方面，Liu等人的研究揭示了LLM在时间序列预测任务中的显著对抗脆弱性。以LLMTime框架为例，通过黑盒梯度自由方法对输入时间序列添加微小扰动（扰动幅度小于原始数据的5%），即可使模型的预测误差恶化300%。这种脆弱性在关键领域应用中危害极大，以电力负荷预测为例，预测误差剧增可能导致电网调度决策失误，进而引发供电故障。针对这一问题，团队提出“时序特征增强+对抗训练”的防护方案：通过小波变换提取时间序列的多尺度特征，强化模型对关键时序信息的捕捉能力，降低对微小扰动的敏感性；同时，将生成的对抗样本纳入训练集，通过针对性对抗训练提升模型对攻击的耐受度。在电力负荷预测、股票价格预测等实际任务中的验证表明，该方案使模型的抗扰动能力提升200%，预测误差波动控制在10%以内，有效保障了LLM在非语言场景中的安全应用。

5.5 AI生成内容（AIGC）安全治理技术

AIGC技术的快速发展带来了深度伪造、虚假信息传播等安全风险，如何实现AIGC内容的精准溯源与鉴伪成为行业难题。2025年，北京大学人工智能研究院研发的“源鉴”系统，在图像、视频、文本三类主流AIGC内容的鉴伪与溯源上实现重大突破，相关成果被CVPR 2025收录。

针对AIGC图像，“源鉴”系统通过提取生成模型的“指纹特征”实现鉴伪。不同生成模型在生成图像时，会因算法逻辑差异在像素层面留下独特的噪声模式，系统通过深度学习模型精准识别这种噪声指纹，鉴伪准确率在各类AIGC图像数据集上均超过98%。对于AIGC视频，系统创新采用“帧间一致性检测+音频特征关联”方法，深度伪造视频往往存在帧间动作不连贯、音频与口型mismatch等问题，系统通过光流法分析帧间运动一致性，结合梅

尔频率倒谱系数（MFCC）提取音频特征，实现对深度伪造视频的精准识别，在DFDC视频数据集上的识别准确率达到97.5%。

内容溯源方面，系统通过在AIGC内容生成时嵌入不可见的数字水印，水印信息包含生成模型标识、生成时间、用户信息等元数据，水印具有强鲁棒性，即使经过裁剪、压缩、滤波等图像处理操作，仍能被准确提取。在新闻媒体领域的试点应用中，“源鉴”系统成功识别出300余条利用AIGC技术生成的虚假新闻，溯源准确率达到99%，有效遏制了虚假信息的传播。

6 AI安全未来研究可能方向

6.1 自适应防御机制

自适应防御机制是应对动态威胁的关键，需实现防御技术的自主学习与进化，摆脱“被动防御”局面。一方面，研发基于强化学习的自适应防御系统，通过与攻击者的持续交互，学习攻击模式与特征，动态调整防御策略，如当系统检测到新型对抗性攻击时，可自动生成对应的对抗样本用于模型训练，提升模型鲁棒性；另一方面，构建“AI安全免疫系统”，借鉴生物免疫系统的原理，实现对未知威胁的快速识别与响应，如通过“免疫记忆”存储已知攻击特征，通过“免疫识别”发现未知攻击的异常模式，通过“免疫应答”启动防御措施。目前，自适应防御技术仍处于起步阶段，未来需重点解决防御系统的学习效率与误报率问题，确保在快速响应威胁的同时，不影响AI系统的正常运行。

6.2 轻量化安全方案

轻量化安全方案则针对边缘设备与中小企业的的需求，研发低资源消耗的安全技术，降低应用门槛。在硬件层面，设计专用的轻量化AI安全芯片，集成加密、认证、异常检测等功能，减少对设备资源的占用；在算法层面，优化隐私保护与对抗性防御算法，降低计算复杂度与通信成本，如提出“轻量化联邦学习”算法，通过压缩模型参数减少传输数据量，提升边缘设备的训练效率；在软件层面，开发轻量化的AI安全监测工具，适用于手机、智能传感器等边缘设备，实现对AI系统的实时安全监控。未来，轻量化安全方案需在安全性与资源消耗之间找到平衡，确保在低资源环境下仍能提供有效的安全防护。

6.3 通用可解释AI

通用可解释AI（XAI）技术是解决“黑箱”问题的核心，需研发适用于各类AI模型的可解释性框架，实现“全场景覆盖”。一方面，探索基于因果推

理的可解释技术，超越传统的相关性分析，揭示输入与输出之间的因果关系，使解释结果更具逻辑性与可靠性；另一方面，构建可解释性与性能协同优化的模型设计方法，避免可解释性提升导致的性能下降，如通过“注意力机制与模型压缩结合”，在提升可解释性的同时，保持模型的轻量化与高效性。此外，还需建立可解释性评估标准，量化模型的可解释程度，为不同场景选择合适的XAI 技术提供依据。未来，通用XAI 技术将在医疗、司法、金融等关键领域发挥重要作用，成为AI 安全的核心支撑。

6.4 跨学科融合与攻防对抗

未来AI 安全研究需突破单一学科的局限，采用跨学科融合与攻防对抗的研究范式，提升研究的全面性与实战性。

跨学科融合研究需进一步整合AI 技术、网络安全、法学、伦理学、社会学等多领域知识，构建全方位的AI 安全研究体系。在技术与法学融合方面，研究AI 安全事故的法律责任认定机制，制定适应AI 技术特点的法律法规，如明确AI 模型开发者、使用者、监管者的责任边界；在技术与伦理学融合方面，探索伦理原则嵌入AI 系统的技术路径，如将“公平性”准则转化为算法约束条件，确保模型决策符合伦理要求；在技术与社会学融合方面，分析AI 安全事件的社会影响，研究公众对AI 安全的认知与接受度，为政策制定提供社会层面的参考。此外，还需培养跨学科的AI 安全人才，通过设立交叉学科专业、开展联合培养项目，打造既懂AI 技术又熟悉法律、伦理的复合型人才队伍。攻防对抗研究则通过构建“攻防演练平台”，模拟真实的攻击场景，提升防御技术的实战能力。一方面，建立大规模的AI 安全攻防数据集，涵盖各类攻击手段与应用场景，为攻防研究提供数据支撑；另一方面，举办AI 安全攻防竞赛，邀请全球研究者与黑客团队参与，通过实战演练发现防御技术的不足，推动技术创新。例如，美国DARPA 举办的“AI 防御挑战赛”，已成为全球AI 安全领域的重要赛事，推动了多项新型防御技术的研发。未来，攻防对抗研究需进一步贴近真实应用场景，引入动态攻击环境与多维度评估指标，确保防御技术在实际应用中有效。

6.5 产业与政策推动

未来AI 安全的产业与政策发展需聚焦分级分类监管、技术产业化落地与全球协同治理，实现技术安全与产业发展的协同推进。

分级分类的AI 安全监管规则是平衡安全与创新的關鍵，需根据AI 应用的风险等级与应用场

景，制定差异化的监管措施。对于低风险AI 应用，采用“备案制”，简化监管流程，鼓励创新；对于中风险AI 应用，采用“审核制”，要求企业提交安全评估报告，确保符合基本安全要求；对于高风险AI 应用，采用“认证制”，通过严格的安全测试与认证，方可投入使用。此外，还需建立AI 安全风险动态评估机制，根据技术发展与应用场景变化，调整风险等级与监管措施。分级分类监管不仅能降低企业合规成本，还能集中资源保障高风险场景的安全，推动AI 产业健康发展。

推动AI 安全技术产业化落地需加强产学研协同，降低技术应用门槛，为企业提供成熟的安全解决方案。一方面，鼓励AI 安全企业开发标准化的安全产品与服务，如对抗性防御软件、数据隐私保护平台、AI 安全监测系统，满足不同行业的需求；另一方面，建立AI 安全技术推广平台，为中小企业提供技术咨询、培训与试用服务，帮助其快速部署安全措施。政府可通过专项资金支持、税收优惠等政策，鼓励企业加大AI 安全技术研发与应用投入；同时，推动AI 安全纳入企业社会责任评价体系，引导企业重视安全建设。未来，AI 安全产业需形成“技术研发-产品化-推广应用”的完整链条，成为AI 产业发展的重要支撑。

建立全球协同的AI 安全治理体系是应对全球威胁的必然选择，需加强国际间的政策协调、技术合作与信息共享。首先，推动建立“全球AI 安全治理联盟”，由各国政府、国际组织、企业与科研机构共同参与，制定统一的AI 安全伦理准则与技术标准；其次，完善AI 安全威胁情报共享机制，建立跨国界的威胁情报数据库，实现攻击特征、防御技术的实时共享；最后，加强国际间的执法合作，针对跨境AI 安全犯罪，建立联合调查与惩处机制，形成全球范围内的威慑力。此外，还需关注发展中国家的AI 安全需求，通过技术援助、能力建设等项目，提升其AI 安全防护水平，缩小全球AI 安全差距。未来，全球AI 安全治理需实现“政策协同、技术共享、执法联动”，构建人类命运共同体层面的AI 安全防护网络。

7 结论与展望

7.1 研究总结

本研究系统梳理了人工智能（AI）安全领域的核心脉络，全面剖析了技术-伦理-管理三维度下的对抗性攻击、数据/模型层面威胁、供应链风险及AI 恶意使用等核心威胁类型，深入阐释了技术层面可解释性缺失、鲁棒性不足、动态防御适配困难，伦理法律层面隐私保护困境、算法公平性失

衡、问责机制缺位、全球监管协同不足,以及落地层面成本高、安全与易用性难平衡、多技术融合复杂等关键挑战。研究构建了“多层次技术防护-全生命周期安全管控-跨域协同治理”三位一体的AI安全缓解策略体系,系统总结了数据安全与隐私保护、模型鲁棒性增强、大模型安全与可解释性、多模态安全等方向的前沿科研成果。研究证实,AI安全并非单一技术问题,而是涉及技术、伦理、法律、管理等多领域的复杂系统工程,其防护体系需突破单点防御思维,通过动态适配的技术手段、全流程的管理机制、全球化的协同治理,实现技术创新与安全保障的动态平衡。

7.2 研究局限

本综述虽覆盖了AI安全领域的核心维度与主流成果,但仍存在若干局限:其一,对生成式AI、具身智能等新兴AI技术衍生的安全威胁分析深度不足,此类技术的模态融合特性、自主决策能力可能催生新型攻击路径,尚未纳入本研究的核心分析框架;其二,对边缘计算、端边云协同场景下的轻量化安全方案探讨较为浅层,未能充分结合设备算力约束、实时性要求等实际落地条件展开分析;其三,受限于公开案例的完整性,部分工业级AI安全事件的技术细节与损失量化数据获取不足,可能影响对威胁危害程度与防御策略效果的精准评估;其四,对发展中国家AI安全治理的差异化需求关注较少,未能充分体现全球AI安全防护的区域不均衡性。

7.3 未来展望

短期看来,AI安全研究与实践需聚焦生成式AI、多模态大模型的安全治理:一方面,加快研发针对AIGC内容溯源、鉴伪的标准化技术体系,建立生成式AI安全评估与备案机制,遏制虚假信息传播、深度伪造等恶意使用行为;另一方面,完善医疗、自动驾驶、金融等高风险场景的AI安全测试基准与认证体系,推动对抗性防御、隐私计算等成熟技术的规模化落地,降低关键领域AI安全事故发生率。

需攻克AI安全核心技术瓶颈与产业落地障碍:技术层面,重点突破自适应防御机制、通用可解释AI(XAI)等关键技术,构建“主动识别-实时响应-动态进化”的智能安全防护体系,解决现有防御技术泛化性差、解释性与性能难以兼顾的问题;产业层面,推动AI安全技术轻量化、产品化,降低中小企业与边缘设备的安全部署成本,建立产学研协同的AI安全人才培养体系;监管层面,完善分级分类的AI安全监管规则,实现“低风险备案、中风险审核、高风险认证”的差异化管

控,平衡安全约束与产业创新活力。

站在长期角度,需构建全球协同的AI安全治理生态:推动建立全球统一的AI安全伦理框架与技术标准,完善跨国界的威胁情报共享、执法协作机制,缩小不同国家和地区的AI安全防护能力差距;将“安全左移”理念融入AI技术研发全流程,实现从数据采集、模型训练到部署运维的全生命周期安全嵌入;最终形成技术自主可控、管理规范有序、治理协同高效的全球AI安全格局,确保AI技术在安全边界内持续赋能经济社会发展,实现技术进步与人类共同利益的统一。

参考文献

- [1] Yazmyradov S. A Comprehensive Review of AI Security: Threats, Challenges, and Mitigation Strategies[J]. The International Journal of Internet, Broadcasting and Communication, 2024, 16(4): 375-384.
- [2] Jourin.对抗性攻击:AI眼中“皇帝的新衣”[N].电脑报,2025-09-08(017).DOI:10.28184/n.cnki.ndina.2025.000544.
- [3] 胡瑞斌,苏世帅,王哲.自然语言处理中对抗攻防的可解释性综述[J].浙江师范大学学报(自然科学版),2025,48(02):142-153.DOI:10.16218/j.issn.1001-5051.2025.02.003.
- [4] Rudin, C. (2019). Stop explaining black-box machine learning models for high-stakes decisions and use interpretable models instead. Nature Machine Intelligence, 1(5), 206-215. <https://www.ncbi.nlm.nih.gov/pmc/articles/PMC9122117/>

Yang Yingborn in 2006,now studies in
Nankai University



Background

This study is the final assignment of "Cutting-edge Technologies in Information Security" for a sophomore majoring in Information Security at Nankai University, aiming to conduct a preliminary exploration of AI security based on the knowledge learned in the course.

In the field of AI security, international research has made some progress that can be understood by sophomore students: DARPA has launched projects to study how to defend against adversarial attacks; the European Union has divided AI into different risk levels and required strict tests for high-risk AI. In academia, simple attack methods like FGSM and PGD, and defense methods like adversarial training have been proposed. However, existing research still has gaps that are easy to perceive: most studies only focus on technical threats, ignoring ethical issues like privacy leakage, and lack systematic solutions that cover the entire process of AI from development to use—this is exactly the "systematic security" idea we need to learn.

As a course assignment, this study makes up for the above gaps from a beginner's perspective: it sorts out threats from three simple dimensions, builds a basic response framework combining the course's security knowledge and simple management ideas, and collates easy-to-understand technical cases. Although it cannot involve complex technical principles, it helps me apply the course knowledge to cutting-edge fields.

This assignment does not rely on large research projects, but is completed independently based on the course materials and public reports. Its significance lies in: on the one hand, it tests my ability to integrate the "information security basics" learned in the past two years with the "frontier technologies" of this course; on the other hand, it helps me find my interest direction in the professional field—AI security, laying a foundation for subsequent course learning and practical operations.

Before this assignment, I only learned basic information security knowledge through courses. This assignment is my first attempt to explore the combination of basic knowledge and AI frontier, which makes up for my lack of understanding of "how to apply traditional security to new technologies" and provides a practical experience for my future professional learning.